

Guide du TP 1 : disséquer un courriel d'hameçonnage

TP 1 · Analyser un courriel d'hameçonnage

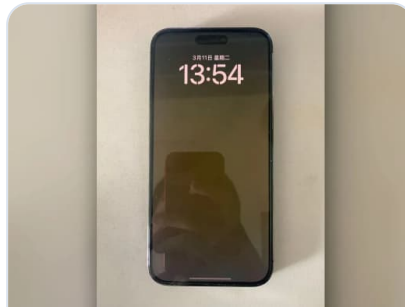


MATÉRIEL QUE TU CROISES DANS CE LABORATOIRE



Ordinateur portable

L'ordinateur que l'on emporte partout



Smartphone

Messages, photos, argent mobile et codes

Photos issues de Wikimedia Commons : Ordinateur portable, Ahunt, CC0 · Smartphone, 茅野ふたば, CC BY-SA 4.0.

CADRE ET LIMITES

- ◆ Toutes les données de ce laboratoire sont fictives.
- ◆ N'ouvre rien sur un vrai système et ne visite aucun vrai site.
- ◆ Ne colle jamais un vrai mot de passe, un vrai code temporaire ou une vraie pièce jointe dans un outil externe.

Méthode

- 1 Lis d'abord les en-têtes : expéditeur réel, adresses de retour, résultats SPF, DKIM et DMARC.
- 2 Compare ensuite le texte affiché du lien et sa vraie destination.
- 3 Termine par les pièces jointes, le délai imposé et les demandes inhabituelles.



Commandes utiles

◆ Windows PowerShell

POWERSHELL

```
Select-String -Path "fond-tp1-courriel.log" -Pattern '^From:', '^Reply-To:', '^Return-Path:', 'spf=|dkim=|dmarc='  
Select-String -Path "fond-tp1-courriel.log" -Pattern 'https://', 'filename='
```

◆ Git Bash ou Linux

BASH

```
grep -EIn '^(from:|reply-to:|return-path:)|spf=|dkim=|dmarc=' fond-tp1-courriel.log  
grep -EIn 'https://|filename=' fond-tp1-courriel.log
```

◆ Variante téléphone ou navigateur

Sur téléphone, appuie longuement sur le lien sans l'ouvrir pour afficher sa vraie destination. Vérifie ensuite le domaine de droite à gauche.



Grille de 10 signaux à vérifier

- 1 Le domaine de l'adresse affichée imite un domaine attendu.
- 2 Reply-To ou Return-Path pointent vers d'autres domaines techniques.
- 3 SPF échoue ou ne valide pas l'expéditeur observé.
- 4 DKIM est absent ou invalide.
- 5 DMARC échoue ou demande une mise en quarantaine.
- 6 Le texte visible du lien et la destination réelle ne correspondent pas.
- 7 La pièce jointe cache une extension exécutable derrière un nom rassurant.
- 8 Le message impose un délai court avant une conséquence négative.
- 9 L'adresse d'expéditeur utilise un grand service grand public.
- 10 Le message demande d'envoyer des coordonnées bancaires complètes par retour de mail.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite. Pour copier les commandes sans coupure de ligne, ouvre la [version texte](#).